

Threat Analysis Report

รายงานการวิเคราะห์ Ransomware
ที่มีเป้าหมายเป็นระบบ VMware ESXi
โดยตรวจพบในประเทศไทย

28/03/2026

TLP:CLEAR





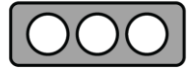
สารบัญ

บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Technique Tactics and Procedures (MITRE ATT&CK).....	9
Indicator of Compromise (IOCs).....	10
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	11
อ้างอิง (References).....	12



บทสรุปสำหรับผู้บริหาร

จากการตรวจสอบพบความพยายามในการโจมตีระบบโครงสร้างพื้นฐานประเภท Virtualization (VMware ESXi) ด้วยมัลแวร์เรียกค่าไถ่ (Ransomware) สายพันธุ์ใหม่ โดยมีพฤติกรรมการโจมตีแบบ Hit-and-Run ที่เน้นความรวดเร็วและทำลายล้างร่องรอย มัลแวร์อาศัยสคริปต์ควบคุม (1.sh) ในการทำ Service Inhibition โดยการใช้คำสั่ง esxcli เพื่อบังคับปิด (Force Kill) Virtual Machines ทั้งหมดในระบบเพื่อปลดล็อกไฟล์เสมือน (.vmdk, .vmx และอื่นๆ) ก่อนจะใช้กลไกการเข้ารหัสแบบ Multi-threading (thpool) เพื่อเพิ่มประสิทธิภาพในการเข้ารหัสข้อมูลขนาดใหญ่ภายในระยะเวลาสั้น และเข้ารหัสนามสกุลไฟล์เป็น “.PKSfjw6dd” จุดเด่นของปฏิบัติการนี้คือการใช้เทคนิค Anti-Forensics ขั้นสูงด้วยการเขียนทับไฟล์มัลแวร์ด้วยข้อมูลสุ่ม ("123123") ก่อนลบทิ้ง และล้างประวัติการใช้คำสั่งระบบเพื่อขัดขวางการตรวจสอบย้อนกลับ นอกจากนี้ผู้ไม่หวังดีได้สร้างความเร่งรีบ (Urgency) โดยระบุเส้นตายในบันทึกเรียกค่าไถ่ (Ransomnote) ให้เป็นวันเดียวกันกับวันที่เริ่มปฏิบัติการ และบังคับให้ติดต่อผ่านช่องทาง TOX messenger เท่านั้น ซึ่งสะท้อนถึงระดับความอันตรายที่องค์กรต้องเร่งเฝ้าระวังและเตรียมแผนการกู้คืนข้อมูลที่เป็นระบบ (Immutable Backup) อย่างเร่งด่วน

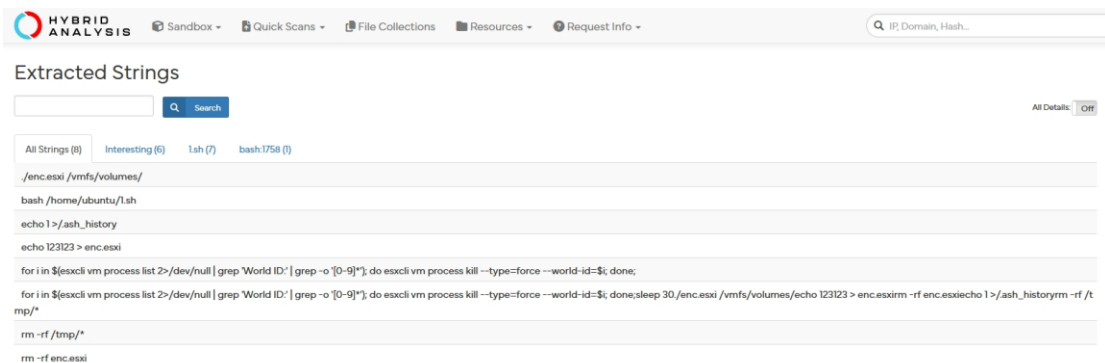


การวิเคราะห์เชิงเทคนิค

1. การวิเคราะห์สคริปต์ตัวนำ (1.sh)

สคริปต์นี้ทำหน้าที่เป็นชุดคำสั่งเตรียมการและควบคุมการทำงาน (Orchestrator) ดังนี้

- 1.1. การขัดขวางการทำงานของระบบ: ใช้คำสั่ง `esxcli vm process list` เพื่อค้นหา World ID ของ VMs ทั้งหมด และใช้ `esxcli vm process kill --type=force` เพื่อสั่งปิด VM ทุกเครื่องทันที
- 1.2. การรันมัลแวร์: หลังจากช่วงเวลา 30 วินาที จะทำการรันไฟล์ `enc.esxi` โดยระบุเป้าหมายที่พาร /vmfs/volumes/ ซึ่งเป็นที่เก็บข้อมูลหลักของ Virtual Disks
- 1.3. การทำลายหลักฐาน (Anti-Forensics):
 - เขียนทับไฟล์มัลแวร์ `enc.esxi` ด้วยค่า "123123" เพื่อป้องกันการวิเคราะห์ไฟล์ภายหลัง
 - ลบไฟล์มัลแวร์ออกจากระบบ
 - ล้างประวัติการใช้คำสั่งใน `.ash_history` และลบไฟล์ชั่วคราวใน `/tmp/*`



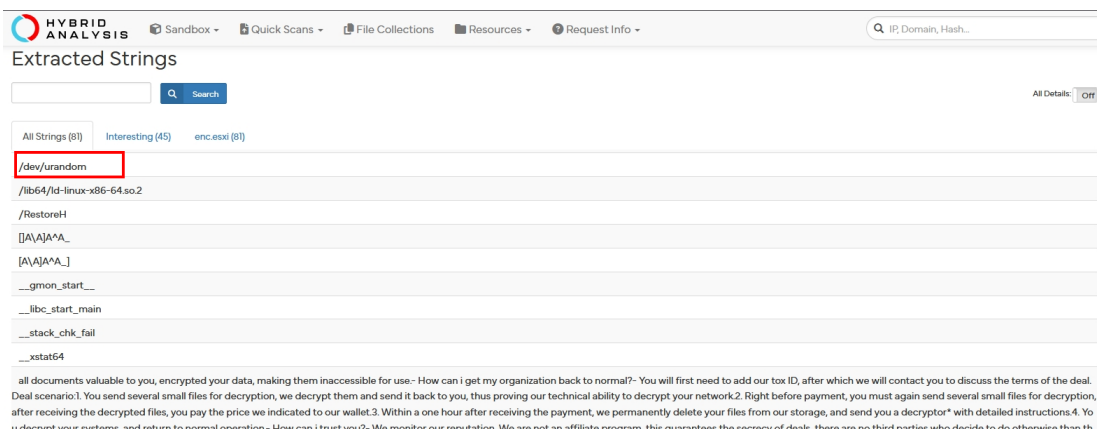
ภาพที่ 1 การวิเคราะห์ Function Strings (1.sh) จาก Hybrid Analysis



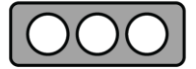
2. การวิเคราะห์ตัวเข้ารหัส (enc.esxi)

จากการตรวจสอบ Strings ภายในไฟล์ พบคุณลักษณะของ Ransomware ดังนี้

- 1.1. เป้าหมายการเข้ารหัส: มุ่งเน้นไฟล์นามสกุลที่เกี่ยวข้องกับ Virtual Machine ได้แก่ .log, .vmx, .ovf, .vmdk, .vmxf, .vmsd, .vmsn, .vswp, .vmss, .vmem, .nvram, และ .ova
มัลแวร์ใช้ข้อมูลจาก /dev/urandom เพื่อนำมาเป็น Seed หรือสร้าง Encryption Key และ Initialization Vector (IV) แบบสุ่มสำหรับแต่ละไฟล์ หรือแต่ละเซสชันการโจมตี
- 1.2. วัตถุประสงค์: มัลแวร์ใช้ข้อมูลจาก /dev/urandom เพื่อนำมาเป็น Seed หรือสร้าง Encryption Key และ Initialization Vector (IV) แบบสุ่มสำหรับแต่ละไฟล์ หรือแต่ละเซสชันการโจมตี
- 1.3. นัยสำคัญต่อการพิสูจน์หลักฐาน (DFIR Significance): การใช้ /dev/urandom ยืนยันว่ากุญแจเข้ารหัสไม่ได้ถูกกำหนดตายตัว (Hardcoded) มาจากตัวมัลแวร์ แต่เป็นการสร้างขึ้นใหม่แบบไดนามิกบนเครื่องเหยื่อ ส่งผลให้การกู้คืนข้อมูลโดยการหา Master Key จากตัวมัลแวร์โดยตรงนั้นทำไม่ได้ และความพยายามในการคาดเดากุญแจ (Brute-force) จะมีความซับซ้อนสูงมากเนื่องจากค่า Entropy ที่ได้จากระบบมีความสุ่มสูง



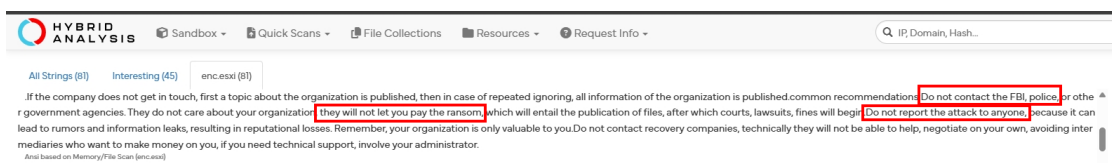
ภาพที่ 2 การใช้ /dev/urandom เพื่อสร้าง Encryption Key บนเครื่องของเหยื่อ



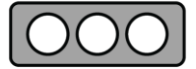
1.4. ประสิทธิภาพการทำงาน: มีการใช้ Thread Pool (thpool) เพื่อประมวลผลการเข้ารหัสแบบขนาน (Multi-threading) ช่วยให้เข้ารหัสข้อมูลปริมาณมากได้อย่างรวดเร็ว

1.5. ข้อความเรียกไถ่ (Ransom Note):

- ระบุว่าข้อมูลถูกขโมยและเข้ารหัสเรียบร้อยแล้ว
- ข่มขู่ว่าจะเผยแพร่ข้อมูลสู่สาธารณะ หรือแจ้งให้คู่ค้าและลูกค้าของเหยื่อทราบหากไม่จ่ายค่าไถ่
- ห้ามติดต่อหน่วยงานบังคับใช้กฎหมาย เช่น FBI หรือตำรวจ ช่องทางติดต่อหลักคือ TOX messenger



ภาพที่ 3 Ransomnote จาก Hybrid Analysis



Attack Flow

Phase 1: Preparation & Service Inhibition (การเตรียมการและระงับบริการ)

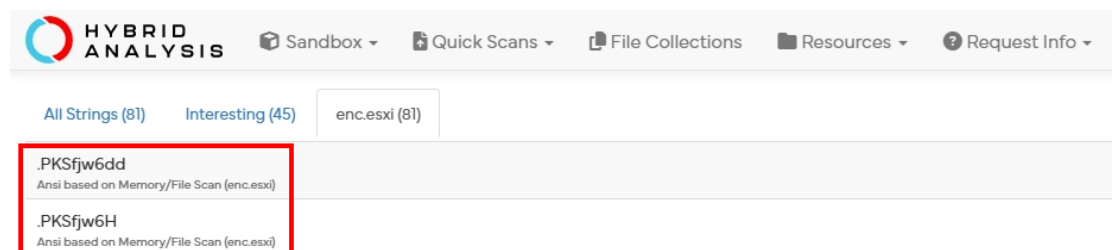
ในระยณนี้ มัลแวร์จะมุ่งเน้นไปที่การทำให้ไฟล์เป้าหมายพร้อมสำหรับการเข้ารหัส

- **Identify Target VMs:** ใช้คำสั่ง `esxcli vm process list` เพื่อดึงรายชื่อและ World ID ของ Virtual Machines ทั้งหมดที่กำลังทำงานอยู่
- **Force Kill Processes:** สั่งปิดการทำงานของ VM ทั้งหมดแบบทันทีด้วยคำสั่ง `esxcli vm process kill --type=force`
- **Unlock Files:** การปิด VM มีวัตถุประสงค์เพื่อปลดล็อกไฟล์ Virtual Disk (.vmdk) เพื่อให้มัลแวร์สามารถเข้าถึงและแก้ไขไฟล์ได้โดยไม่ติดสถานะ "File in use"
- **Trigger Delay:** มีการหน่วงเวลา 30 วินาที (sleep 30) เพื่อให้แน่ใจว่าโปรเซสของ VM ถูกปิดลงอย่างสมบูรณ์ก่อนเริ่มขั้นตอนถัดไป

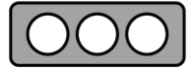
Phase 2: Execution & Data Encryption (การเข้ารหัสทำลายข้อมูล)

เมื่อระบบพร้อม มัลแวร์จะเริ่มกระบวนการเข้ารหัส

- **Targeted Execution:** รันไฟล์ `enc.esxi` โดยระบุพาธเป้าหมายไปที่ `/vmfs/volumes/` ซึ่งเป็นพื้นที่จัดเก็บข้อมูลหลักของระบบ Virtualization
- **Multi-threaded Processing:** มัลแวร์สร้าง Thread Pool เพื่อเข้ารหัสไฟล์พร้อมกันหลายไฟล์ เพื่อเพิ่มความเร็วในการโจมตีระบบที่มีข้อมูลขนาดใหญ่
- **Extension-Specific Encryption:** เจาะจงเข้ารหัสไฟล์นามสกุลสำคัญ เช่น .vmdk, .vmx, .vmem, .nvram, และ .ova
- **File Renaming:** หลังจากเข้ารหัสสำเร็จ มัลแวร์จะต่อท้ายนามสกุลไฟล์ด้วย `.PKSfjw6dd` เพื่อระบุว่าไฟล์ถูกล็อกแล้ว
- **Ransom Note Dropping:** สร้างไฟล์ `-Restore-Your-Files-readme.txt` เพื่อแสดงข้อความเรียกค่าไถ่และข้อมูลการติดต่อผ่าน TOX Messenger



ภาพที่ 4 File Extension ของไฟล์ที่ถูกเข้ารหัส

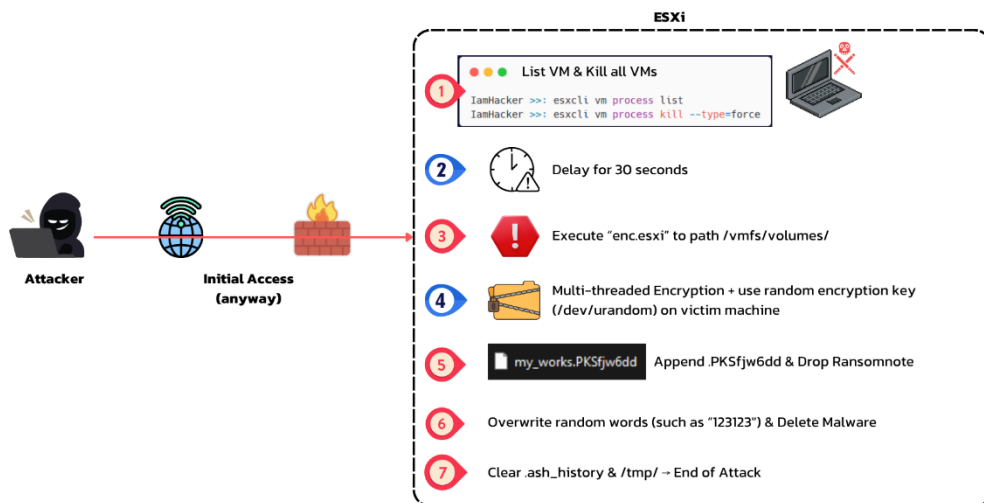


Phase 3: Anti-Forensics & Evidence Destruction (การทำลายร่องรอย)

ขั้นตอนสุดท้ายคือการลบหลักฐานการบุกรุกเพื่อขัดขวางการทำงานของเจ้าหน้าที่ไอที

Malware Overwriting: เขียนทับไฟล์มัลแวร์ enc.esxi ด้วยค่า "123123" เพื่อป้องกันไม่ให้เจ้าหน้าที่กู้คืนไฟล์ต้นฉบับมาวิเคราะห์หา Decryptor ได้

- **Artifact Removal:** ลบไฟล์มัลแวร์ออกจากระบบ และล้างไฟล์ในโฟลเดอร์ /tmp/ ทั้งหมด
- **Log Wiping:** เขียนทับและลบประวัติการพิมพ์คำสั่งในไฟล์ .ash_history เพื่อซ่อนชุดคำสั่งที่ใช้ในการโจมตี



ภาพที่ 5 Attack Flow



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1059.004	Unix Shell: การรันสคริปต์ 1.sh
Defense Evasion	T1070.003	Clear Command History: ลบ .ash_history
Defense Evasion	T1070.004	File Deletion: ลบมัลแวร์และเขียนทับข้อมูล
Impact	T1489	Service Stop: การ Force Kill VM Process
Impact	T1486	Data Encrypted for Impact: การเข้ารหัสไฟล์ VM



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

File Names:

1.sh

enc.esxi

-Restore-Your-Files-readme.txt

File Hash

(1.sh)

12319531c6181af387b551976e71d1bdea8c278bedc8f45ad3f29b8a7e471ac7

(enc.esxi)

062ea75b10c93d85bf2a095fb344276c42aa741cc4d126242b2e97d3de4dc965

TOX ID

DEAB44C0E1C9397268AD96F35D211FA394A1C8B6851DB4141C736038624C4D6C68361B51B31E

Encryption Extension (Suffix)

.PKSfjw6dd



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตั้งค่าการแจ้งเตือน (Alerting) เมื่อมีการใช้คำสั่งหยุดการทำงานของ VM พร้อมกันหลายเครื่อง
- เฝ้าระวังการสร้างไฟล์ที่มีนามสกุลผิดปกติ หรือการเรียกใช้คำสั่งใน path /vmfs/volumes/ และ /dev/urandom

การป้องกัน (Prevention)

- จำกัดสิทธิ์การใช้งานคำสั่ง esxcli และเข้าถึงระดับ Root ของ ESXi Host
- ตรวจสอบความปลอดภัยของไฟล์สคริปต์ในระบบอย่างสม่ำเสมอ

การรับมือ (Response)

- ตัดการเชื่อมต่อเครือข่ายของ Host ที่ติดเชื้อมันเพื่อป้องกันการแพร่กระจาย
- กู้คืนระบบจาก Backup ที่แยกส่วนจากเครือข่ายหลัก (Offline/Immutable Backup)



อ้างอิง (References)

1. Recorded Future (Threat Intelligence)

2. Hybrid Analysis (Sandbox)

[https://hybrid-](https://hybrid-analysis.com/sample/12319531c6181af387b551976e71d1bdea8c278bedc8f45ad3f29b8a7e471ac7)

[analysis.com/sample/12319531c6181af387b551976e71d1bdea8c278bedc8f45ad3f29b8a7e471ac7](https://hybrid-analysis.com/sample/12319531c6181af387b551976e71d1bdea8c278bedc8f45ad3f29b8a7e471ac7)

[https://hybrid-](https://hybrid-analysis.com/sample/062ea75b10c93d85bf2a095fb344276c42aa741cc4d126242b2e97d3de4dc965)

[analysis.com/sample/062ea75b10c93d85bf2a095fb344276c42aa741cc4d126242b2e97d3de4dc965](https://hybrid-analysis.com/sample/062ea75b10c93d85bf2a095fb344276c42aa741cc4d126242b2e97d3de4dc965)



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/we87Pq3TUtWzsF536>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th